Windows 環境で Codex を安全に使うための補足

AI エージェント利用ガイド

目次

- はじめに
- 基本方針
  - 1. ユーザープロファイル直下で使わない
  - 2. 案件ごとの専用ディレクトリーを使う
  - 3. 作業前に権限を確認する
  - 4. Windows 固有の保存場所を意識する
- Codex を起動してはいけない場所
- 認証情報が残りやすい場所
- 環境変数と資格情報マネージャー
  - 環境変数
  - 資格情報マネージャー
- シェル履歴と開発ツール
  - 注意が必要な履歴
  - 対策
- アプリ、ブラウザー、チャットツールのキャッシュ
- OneDrive と SharePoint 同期フォルダー
  - 主なリスク
  - 確認する項目
- WSL 利用時の注意
  - Windows 側を読むリスク
  - Windows 側から WSL を読むリスク
  - 対策
- 企業端末と客先端末での注意
  - 確認する項目
  - 禁止すること
- 安全な作業ディレクトリー例
  - 比較的安全な例
  - 注意が必要な例
  - 避ける例
- 作業前チェックリスト
- まとめ

はじめに

この補足資料は、`Codex を仕事で安全に使うための説明書` を Windows 環境で使う場合の注意点をまとめたものです。

Windows では、ユーザープロファイル、アプリケーションデータ、同期フォルダー、資格情報マネージャー、WSL などに、認証情報、履歴、キャッシュ、社内情報、客先情報が残ることがあります。

本体資料の基本原則は Windows でも同じです。

- AI エージェントに見せる情報を最小限にする
- 読み取り範囲と書き込み範囲を限定する
- コマンド実行とネットワークアクセスを必要時だけ許可する
- 認証情報、個人情報、顧客情報、本番情報を読ませない
- 作業前後に差分、生成物、ログを確認する

本資料では、Windows 固有の危険な場所や確認事項を具体的に示します。

基本方針

Windows で Codex などの AI エージェントを使う場合は、次の方針を守ります。

1. ユーザープロファイル直下で使わない

`C:\Users\<user>` は、Linux や macOS のホームディレクトリーに相当します。SSH 鍵、クラウド認証情報、ダウンロード、デスクトップ、ドキュメント、アプリ設定、履歴、同期フォルダーが集まりやすいため、作業ディレクトリーにしてはいけません。

2. 案件ごとの専用ディレクトリーを使う

案件ごと、客先ごと、用途ごとに作業ディレクトリーを分けます。

例:

- `C:\work\customer-a\project-x`
- `C:\dev\project-name`
- `D:\work\project-name`

ただし、上位ディレクトリーに別案件や秘密情報がある場合は、その上位ディレクトリーを AI エージェントに広く読ませてはいけません。

3. 作業前に権限を確認する

作業前に、AI エージェントが読める範囲、変更できる範囲、実行できる操作、ネットワークアクセスの可否、外部連携の有無を確認します。

4. Windows 固有の保存場所を意識する

Windows では、アプリケーションデータ、資格情報マネージャー、PowerShell 履歴、OneDrive 同期フォルダー、WSL などに情報が残ることがあります。見た目の作業ディレクトリーだけで安全と判断してはいけません。

Codex を起動してはいけない場所

次の場所を作業ディレクトリーにしたり、AI エージェントが広く読める状態にしたりしてはいけません。

場所	含まれる可能性がある情報
`C:\Users\<user>`	ユーザー設定、SSH 鍵、クラウド認証情報、履歴、他案件情報
`C:\Users\<user>\Desktop`	顧客資料、契約書、見積書、一時的な作業ファイル
`C:\Users\<user>\Downloads`	メール添付、顧客資料、インストーラー、圧縮ファイル
`C:\Users\<user>\Documents`	社内文書、客先資料、設計書、個人情報
`%USERPROFILE%`	ユーザープロファイル全体
`%APPDATA%`	アプリ設定、トークン、履歴、キャッシュ
`%LOCALAPPDATA%`	ブラウザー、チャット、開発ツールのローカルデータ
`C:\ProgramData`	全ユーザー向け設定、サービス設定、ツール設定
`C:\Windows`	OS 設定、システムファイル
`C:\Windows\System32`	システムコマンド、設定、管理機能
`C:\Windows\System32\config`	レジストリ関連ファイル、システム設定
`C:\Windows\Temp`, `C:\Temp`	一時ファイル、ログ、ダンプ、他プロセスの出力

これらの場所で AI エージェントを起動する必要がある場合は、読み取り範囲と書き込み範囲を明示的に制限し、機密情報や別案件情報が見えない状態にします。

認証情報が残りやすい場所

Windows では、ユーザープロファイル配下にさまざまな認証情報や接続先情報が保存されます。

場所	主なリスク
`%USERPROFILE%\.ssh`	SSH 秘密鍵、接続先、known_hosts
`%USERPROFILE%\.aws`	AWS の認証情報、プロファイル、接続先
`%USERPROFILE%\.azure`	Azure CLI の認証情報やキャッシュ
`%USERPROFILE%\.kube`	Kubernetes クラスタ接続情報
`%USERPROFILE%\.docker`	Docker レジストリー認証、Docker 設定
`%USERPROFILE%\.gitconfig`	Git 設定、ユーザー情報、credential helper 設定
`%USERPROFILE%\.npmrc`	npm レジストリーの認証トークン
`%USERPROFILE%\.pypirc`	Python パッケージ公開用の認証情報
`%APPDATA%\GitHub CLI`	GitHub CLI の設定や認証情報
`%APPDATA%\Code\User`	VS Code 設定、拡張機能設定、履歴

これらの場所が作業範囲に含まれていると、AI エージェントが認証情報や接続先を読む可能性があります。

対策:

- 認証情報がある場所を作業ディレクトリーにしない
- 必要な場合はダミー設定や検証用アカウントを使う
- 本番クラウド、客先クラウド、管理者権限の認証情報を持つ環境で使わない
- 漏洩した可能性がある場合は、トークンや鍵をローテーションする

環境変数と資格情報マネージャー

Windows では、ユーザー環境変数、システム環境変数、PowerShell セッション変数、資格情報マネージャーに秘密情報が残ることがあります。

環境変数

環境変数には次のような情報が入ることがあります。

- API キー
- DB 接続文字列
- プロキシ認証情報
- クラウド認証情報
- 社内サービスの接続先
- 一時トークン

注意が必要な操作:

- `set`
- `Get-ChildItem Env:`
- `gci env:`
- `echo %VARIABLE_NAME%`
- `$env:VARIABLE_NAME`

AI エージェントにコマンド実行を許可している場合、環境変数を表示できる可能性があります。

資格情報マネージャー

Windows Credential Manager には、Git、ブラウザー、クラウド、社内サービスの資格情報が保存されることがあります。

注意点:

- 資格情報マネージャーの内容を AI に読ませない
- `cmdkey` などで保存済み資格情報を一覧表示しない
- Git credential helper の保存先を確認する
- 客先端末では客先の管理ポリシーに従う

シェル履歴と開発ツール

Windows では、PowerShell、cmd、Git Bash、Windows Terminal、開発ツールにコマンド履歴や接続情報が残ることがあります。

注意が必要な履歴

対象	例
PowerShell 履歴	`ConsoleHost_history.txt`
Windows Terminal	プロファイル、起動コマンド、履歴
cmd	バッチファイル、手入力コマンド、環境変数
Git Bash	`.bash_history`、`.profile`、`.bashrc`
VS Code	最近開いたフォルダー、拡張機能設定、ターミナル履歴

履歴には、接続先、トークン、パスワード付き URL、客先環境名、作業ログが含まれることがあります。

対策

- 履歴ファイルを作業範囲に含めない
- 秘密情報をコマンドライン引数に書かない
- トークンやパスワードを含むコマンドを AI に見せない
- ターミナル履歴を共有前に確認する
- 検証用の一時トークンを使う

アプリ、ブラウザー、チャットツールのキャッシュ

Windows のアプリケーションデータには、セッション、Cookie、キャッシュ、添付ファイル、閲覧履歴、チャット履歴が残ることがあります。

注意が必要な例:

- Microsoft Edge
- Google Chrome
- Firefox
- Outlook
- Teams
- Slack
- Zoom
- OneDrive
- GitHub Desktop
- VS Code

保存場所の例:

- `%LOCALAPPDATA%\Microsoft`
- `%LOCALAPPDATA%\Google`
- `%APPDATA%\Mozilla`
- `%APPDATA%\Slack`
- `%APPDATA%\Microsoft\Teams`
- `%APPDATA%\Code`

これらのディレクトリーを作業対象にすると、AI エージェントがセッション情報、添付ファイル、履歴、社内情報、客先情報を読む可能性があります。

対策:

- アプリデータ配下を作業ディレクトリーにしない
- キャッシュや添付ファイルを AI に読ませない
- ログやエクスポートファイルを共有する前にマスクする
- 客先端末ではアプリデータの持ち出しや解析を行わない

OneDrive と SharePoint 同期フォルダー

企業端末では、OneDrive や SharePoint の同期フォルダーが `Desktop`、`Documents`、`Pictures`、プロジェクトフォルダーと連動している場合があります。

主なリスク

- 生成物や一時ファイルが意図せずクラウドへ同期される
- 客先情報や社内限定情報が同期フォルダーに残る
- 別案件のファイルが同じ同期領域に混在する
- PDF、ログ、スクリーンショット、作業履歴が自動保存される
- 削除したつもりのファイルがクラウド側に残る

確認する項目

- 作業ディレクトリーが OneDrive や SharePoint 配下ではないか
- Desktop、Documents、Downloads が同期対象になっていないか
- 客先情報を同期フォルダーに置いてよい契約か
- 生成物の保存先が許可されているか
- 同期履歴、バージョン履歴、削除済みファイルの扱いはどうなるか

原則として、客先データや機密情報を扱う作業では、同期フォルダーを作業ディレクトリーにしません。

WSL 利用時の注意

Windows Subsystem for Linux を使う場合、Windows 側と Linux 側の境界に注意します。

Windows 側を読むリスク

WSL からは、設定によって Windows 側のファイルにアクセスできます。

例:

- `/mnt/c/Users/<user>`
- `/mnt/c/Users/<user>/Desktop`
- `/mnt/c/Users/<user>/Downloads`
- `/mnt/c/Users/<user>/.ssh`
- `/mnt/c/Users/<user>/.aws`

WSL 内で AI エージェントを使っているつもりでも、`/mnt/c` 経由で Windows のホームや認証情報が見える場合があります。

Windows 側から WSL を読むリスク

Windows 側から WSL のファイルシステムへアクセスできる場合もあります。

例:

- `\\wsl$`
- `\\wsl.localhost`

WSL 内の作業ディレクトリーに客先情報や秘密情報を置く場合は、Windows 側のアプリや同期ツールから見える可能性も考慮します。

対策

- WSL から `/mnt/c/Users/<user>` を広く読ませない
- Windows 側のホーム配下を WSL の作業対象にしない
- WSL 内にも `.env`、秘密鍵、本番ログ、客先データを置かない
- Windows 側と WSL 側の両方で読み取り範囲を確認する

企業端末と客先端末での注意

企業端末、貸与 PC、客先端末、VDI では、個人判断で AI エージェントを導入したり、外部通信を許可したりしてはいけません。

確認する項目

- AI エージェントの利用が会社または客先に許可されているか
- 利用できる AI ツール名、プラン、アカウントが明確か
- クラウド AI への送信が許可されているか
- 客先端末にツールをインストールしてよいか
- 社内 VPN や客先 VPN から外部 API へ接続してよいか
- EDR、MDM、プロキシ、監査ログのポリシーに反しないか
- 作業ログ、プロンプト履歴、生成物の保存先が許可されているか

禁止すること

- 客先の許可なく AI エージェントを使う
- 貸与 PC に無断で AI ツールをインストールする
- 社内 VPN や客先 VPN 経由で未承認の外部通信を行う
- 客先の認証情報や秘密鍵を AI に読ませる
- 生成物や作業履歴を無断で自社環境へ持ち帰る

企業端末や客先端末では、自社ルールと客先ルールのうち、より厳しい条件を適用します。

安全な作業ディレクトリー例

安全な作業ディレクトリーは、案件ごとに分離され、不要な秘密情報や別案件情報を含まない場所です。

比較的安全な例

- `C:\work\customer-a\project-x`
- `C:\work\internal\tooling-docs`
- `C:\dev\project-name`
- `D:\work\project-name`

注意が必要な例

- `C:\work`
- `C:\dev`
- `D:\projects`

これらの上位ディレクトリーには、複数案件や別顧客の情報が混在しやすいため、AI エージェントに広く読ませないようにします。

避ける例

- `C:\Users\<user>`
- `C:\Users\<user>\Desktop`
- `C:\Users\<user>\Downloads`
- `C:\Users\<user>\Documents`
- OneDrive や SharePoint の同期フォルダー
- `%APPDATA%`
- `%LOCALAPPDATA%`
- `C:\Windows`
- `C:\ProgramData`

安全な場所であっても、作業前に `.env` 、秘密鍵、本番ログ、顧客データ、個人情報がないことを確認します。

作業前チェックリスト

Windows 環境で AI エージェントを使う前に、次の項目を確認します。

- [ ] `C:\Users\<user>` 直下で起動していない
- [ ] Desktop、Downloads、Documents を作業場所にしていない
- [ ] OneDrive や SharePoint の同期フォルダーを作業場所にしていない
- [ ] `%APPDATA%`、`%LOCALAPPDATA%`、`C:\ProgramData` が作業範囲に入っていない
- [ ] `%USERPROFILE%\.ssh`、`.aws`、`.azure`、`.kube`、`.docker` が作業範囲に入っていない
- [ ] `.env`、秘密鍵、API キー、DB 接続情報がない
- [ ] PowerShell、cmd、Git Bash、Windows Terminal の履歴に秘密情報がない
- [ ] 環境変数に秘密情報や本番接続情報がない
- [ ] 資格情報マネージャーの内容を AI に読ませない
- [ ] WSL から Windows 側のホームを広く読ませない
- [ ] Windows 側から WSL 内の秘密情報が見える状態ではない
- [ ] 客先業務の場合、客先の AI 利用許可を確認した
- [ ] コマンド実行、ネットワークアクセス、外部連携の要否を確認した

まとめ

Windows 環境では、ユーザープロファイル、アプリケーションデータ、同期フォルダー、資格情報マネージャー、WSL 境界に注意します。

安全に使うための要点は次のとおりです。

1. `C:\Users\<user>` 直下で AI エージェントを使わない
2. Desktop、Downloads、Documents、同期フォルダーを作業場所にしない
3. `%APPDATA%`、`%LOCALAPPDATA%`、認証情報ディレクトリーを読ませない
4. 環境変数、資格情報マネージャー、シェル履歴を確認する
5. WSL では Windows 側と Linux 側の両方の読み取り範囲を確認する
6. 案件ごとの専用ディレクトリーで作業する
7. 客先端末や企業端末では、自社ルールと客先ルールのうち厳しい方を適用する

Windows でも基本は同じです。AI エージェントの安全性は、どの情報を見せ、どの操作を許可し、どの環境で使うかによって決まります。